



OROACTIVE ACADEMY

CORSO AVANZATO NORMATIVA E SICUREZZA OPERATIVA

Identificazione, tracciabilità, AML, privacy, audit e gestione degli incidenti

Manuale ufficiale di alta specializzazione interna

Cliente

Documenti

Pagamenti

AML

Privacy

Audit

Autorità

Sospensioni

Data breach

OBIETTIVO

Autonomia conforme e controllata

Identificare, tracciare, pagare, sospendere e reagire senza perdere evidenze o violare diritti.

USO

Alta specializzazione interna

Commessi evoluti, responsabili, Founder, compliance, privacy e sicurezza.

**Nota: il corso è formazione interna e non sostituisce consulenza legale, DPO, responsabile AML, autorità o policy aggiornate.
Aggiornamento normativo consultato: 22 giugno 2026. In caso di dubbio prevalgono legge vigente e istruzioni aziendali approvate.**

OROACTIVE ACADEMY

Scheda corso

Corso Avanzato Normativa e Sicurezza Operativa - compliance, tracciabilità, antiriciclaggio, privacy e incident response

Percorso di alta specializzazione per rendere il commesso autonomo nei casi standard e rigoroso nell'escalation dei casi non standard. Il corso insegna a distinguere obbligo legale, procedura aziendale e prudenza operativa; a preservare documenti ed evidenze; a utilizzare correttamente il gestionale; a fermarsi quando la certezza non è sufficiente.

Campo	Dettaglio
Destinatari	Commessi evoluti, responsabili, supervisori, Founder, compliance, privacy e sicurezza.
Prerequisiti	Corso Operativo Completo Compro Oro, conoscenza base del gestionale e delle procedure di valutazione.
Obiettivo	Gestire cliente, pratica, pagamento, dati, anomalie, autorità e incidenti in modo conforme e tracciabile.
Durata consigliata	40-52 ore di studio, 16 ore di simulazioni, esercitazioni su documenti e incident tabletop.
Metodo	Norme tradotte in workflow, matrici, check-list, casi studio, audit trail, quiz ed esame pratico.
Esito atteso	Operatore capace di eseguire procedure standard e sospendere correttamente i casi critici.

Uso corretto del corso

Le soglie e le procedure devono essere verificate contro legge vigente, circolari OAM/UIF, policy OroActive, indicazioni del DPO e del responsabile AML. Il commesso non interpreta autonomamente casi giuridici complessi: raccoglie fatti, preserva evidenze e attiva il ruolo competente.

Competenze finali

- Identificare il cliente prima dell'operazione e verificare documenti, coerenza e capacità di agire.
- Creare una pratica completa, progressiva, fotografata, ricevuta e collegata alla destinazione dei beni.
- Applicare la soglia speciale dei 500 euro e riconoscere il frazionamento di operazioni economicamente unitarie.
- Individuare anomalie AML senza automatismi, discriminazioni o scorciatoie basate su un solo indicatore.
- Proteggere dati e documenti secondo minimizzazione, limitazione delle finalità, sicurezza e conservazione.
- Utilizzare audit trail, ruoli, autorizzazioni e blocchi software come controlli sostanziali, non decorativi.
- Gestire ispezioni, richieste delle autorità, sospensioni, incidenti operativi e data breach.



STRUTTURA UFFICIALE DEL CORSO

Indice - parte I

Modulo	Titolo	Contenuto operativo
01	Architettura normativa	D.Lgs. 92/2017, AML, GDPR, TULPS, OAM, UIF e policy.
02	Ruoli e responsabilità	Founder, responsabile, commesso, privacy, AML, IT e segregazione.
03	Identificazione cliente	Dati, documenti, verifica, rappresentanza e casi non standard.
04	Documenti sospetti	Red flags, incoerenze, scadenza, alterazioni e identity fraud.
05	Tracciabilità pratica	Scheda progressiva, descrizione, foto, ricevuta e destinazione.
06	Pagamenti	Soglia 500 euro, frazionamento, disponente, conto dedicato.
07	Antiriciclaggio	Approccio basato sul rischio, indicatori e comportamento.
08	SOS e riservatezza	Valutazione, escalation, invio, no tipping off e UIF.
09	Privacy	Principi GDPR, basi giuridiche, informative e minimizzazione.

Metodo

Ogni modulo distingue: obbligo normativo, controllo OroActive, evidenza da produrre e condizione di stop.



STRUTTURA UFFICIALE DEL CORSO

Indice - parte II

Modulo	Titolo	Contenuto operativo
10	Conservazione documentale	Dieci anni, integrità, storicità, accessi e cancellazione controllata.
11	Audit trail e sicurezza accessi	Utenti univoci, least privilege, versioni, log e backup.
12	Autorità e ispezioni	Richieste formali, consegna evidenze e catena di custodia.
13	Sospensioni e autorizzazioni	Matrice rischio, override, comunicazione al cliente e riapertura.
14	Incident management	Eventi fisici, operativi, cyber e responsabilità.
15	Data breach	Classificazione, contenimento, 72 ore, interessati e registro.
16	Business continuity	Fallback, ripristino, numerazione, riconciliazione e test.
17	Governance e controlli	KPI, audit periodici, sanzioni, formazione e miglioramento.
18	Casi studio ed esame	Scenari completi, checklist, tabletop e certificazione interna.

Regola madre

L'operatore autonomo non è chi conclude sempre. È chi sa quando concludere, quando sospendere e quale evidenza lasciare.

01

Architettura normativa

Dalla legge alla singola azione in app

1. Mappa delle fonti

ARCHITETTURA NORMATIVA E OPERATIVA

Legge speciale compro oro

D.Lgs. 92/2017

Antiriciclaggio

D.Lgs. 231/2007 + UIF

Privacy e sicurezza dati

GDPR + Codice Privacy

Pubblica sicurezza e autorizzazioni

TULPS, OAM, autorità

Policy OroActive

ruoli, soglie, workflow, audit

La policy aziendale può essere più prudente della soglia legale, mai meno protettiva o contraria alla legge.

La conformità non deriva da una singola norma. L'attività di compro oro combina regole speciali di identificazione e tracciabilità, obblighi antiriciclaggio, tutela dei dati, autorizzazioni di pubblica sicurezza e controlli aziendali. Il commesso lavora sull'ultimo livello della piramide, ma deve riconoscere quale livello impone una determinata azione.

Fonte	Domanda operativa
D.Lgs. 92/2017	Chi identificare, come tracciare la pratica, quali foto e quanto conservare?
D.Lgs. 231/2007 e UIF	Ci sono anomalie o sospetti da valutare e segnalare?
GDPR e Codice Privacy	Quali dati trattare, per quanto tempo e con quali misure?
TULPS e OAM	L'operatore e la sede sono autorizzati e registrati?
Policy OroActive	Quale ruolo decide, quali blocchi si applicano e quale audit è richiesto?

Principio

La legge fissa il minimo. La policy può essere più prudente, ma non può eliminare un obbligo o creare scorciatoie non conformi.

01

Obbligo legale e policy

Evitare due errori opposti: sottovalutare o inventare obblighi

1.1 Quattro livelli di regola

Livello	Esempio	Comportamento
Obbligo legale	Identificare ogni cliente prima dell'operazione.	Sempre, senza eccezioni operative.
Istruzione autorità	Indicatori UIF e istruzioni SOS.	Usare nel processo valutativo.
Policy aziendale	Secondo controllo sopra soglia interna.	Applicare finché vigente.
Buona pratica	Fotografia aggiuntiva di dettaglio.	Usare se utile e proporzionata.

Un operatore deve saper spiegare il fondamento della propria azione. La frase corretta non è "il sistema lo chiede", ma "questa verifica è richiesta dalla procedura per adempiere a identificazione, tracciabilità o sicurezza".

Errore	Rischio	Correzione
Saltare un campo obbligatorio	Pratica incompleta e sanzionabile.	Bloccare la chiusura.
Chiedere dati non necessari	Violazione di minimizzazione.	Rimuovere la raccolta eccedente.
Trattare una policy come legge	Comunicazione scorretta al cliente.	Dichiarare che è procedura aziendale.
Ignorare una policy prudenziale	Rischio operativo e disciplinare.	Escalation se non applicabile.

Domanda guida

Quale fatto sto verificando? Quale rischio riduco? Quale evidenza rimane? Chi può autorizzare l'eccezione?

02

Ruoli e responsabilità

Segregare esecuzione, controllo e decisione

2. La responsabilità non si condivide in modo indistinto

Ruolo	Responsabilità tipica	Non deve fare
Commesso	Raccoglie dati, verifica, documenta, applica blocchi.	Autorizzarsi da solo una deroga critica.
Responsabile	Convalida eccezioni, controlla qualità, gestisce incidenti.	Cancellare tracce o sostituirsi all'autorità.
Founder/Delegato	Definisce policy, soglie, ruoli e governance.	Usare privilegi senza motivazione.
Responsabile AML/SOS	Valuta anomalie e gestisce segnalazioni.	Rivelare la SOS al cliente.
DPO/Privacy	Supporta basi giuridiche, diritti e breach.	Assumere decisioni operative del negozio.
IT/Security	Protegge sistemi, log, backup e accessi.	Leggere dati senza necessità autorizzata.

Segregazione

Chi crea una pratica non dovrebbe poter cancellare audit, alterare log o approvare autonomamente un pagamento anomalo.

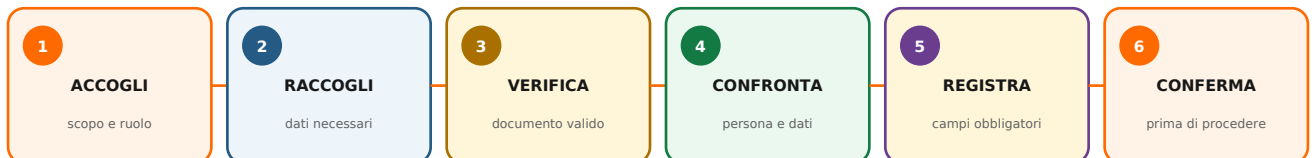
La matrice RACI interna deve indicare per ogni evento chi esegue, chi approva, chi viene consultato e chi viene informato. I ruoli tecnici non sostituiscono la responsabilità del titolare o della direzione.

03

Identificazione del cliente

Prima di valutare il bene, rendere certo chi sta operando

3. Sequenza standard

IDENTIFICAZIONE PRIMA DELL'OPERAZIONE*Ogni passaggio deve essere dimostrabile, autorizzato e ricostruibile.*

Dato	Controllo minimo
Nome e cognome	Corrispondenza documento/persona.
Nascita e residenza	Completezza e coerenza.
Codice fiscale	Formato e corrispondenza ai dati.
Documento	Tipo, numero, autorità, rilascio, scadenza.
Cittadinanza	Solo se prevista dal flusso e correttamente documentata.
Ruolo nell'operazione	Proprietario, delegato, rappresentante: da chiarire.

Stop immediato

Non proseguire se identità, capacità di agire o legittimazione non sono ragionevolmente verificabili secondo procedura.

03

Documento di identità

Validità formale, coerenza sostanziale e controllo visivo

3.1 Check-list del documento

Area	Cosa osservare	Anomalia
Integrità	Supporto, bordi, foto, zone dati.	Tagli, sovrapposizioni, abrasioni.
Validità	Scadenza e data rilascio.	Scaduto o cronologia impossibile.
Coerenza	Età, foto, firma, dati anagrafici.	Persona non corrispondente.
Numero	Formato e leggibilità.	Caratteri alterati o incompleti.
Autorità	Indicazione plausibile.	Campo assente o incoerente.
Sicurezza	Elementi visibili e comportamento alla luce.	Riproduzione piatta o stampa anomala.

Il commesso non effettua una perizia documentale forense. Esegue controlli di primo livello, acquisisce immagini secondo la procedura approvata e sospende quando la coerenza non è sufficiente.

Regola privacy

La copia o scansione del documento deve avere una base giuridica e una finalità definite. Non acquisire più immagini, lati o dati di quanto richiesto dalla procedura approvata.

Evidenza minima

Annotare esito, tipo di controllo e motivo dell'eventuale sospensione. Non scrivere giudizi offensivi o diagnosi non dimostrate.

03

Casi non standard

Delegati, persone giuridiche, capacità e incongruenze

3.2 Prima di procedere, chiarire il ruolo

Scenario	Verifica richiesta	Decisione
Cliente per conto di terzi	Titolarità e ragione della rappresentanza.	Sospendere se non documentata.
Persona giuridica	Esistenza, rappresentante e poteri.	Procedura dedicata.
Delega	Identità delegante/delegato e validità.	Escalation se incompleta.
Minore o capacità dubbia	Capacità di agire e rappresentanza legale.	Non concludere senza verifica.
Documento estero	Validità, lingua, dati e policy.	Verifica superiore se necessario.
Dati divergenti	CF, residenza, nome o data non allineati.	Correggere con fonte valida.

Non improvvisare

Il commesso non interpreta procure, sentenze o assetti societari complessi. Raccoglie il documento, blocca e coinvolge il responsabile/legal.

La pressione del cliente, l'urgenza o la notorietà non sostituiscono la prova dei poteri. La relazione commerciale non deve ridurre i controlli.

04

Documenti sospetti

Dall'anomalia al blocco senza accusare il cliente

4. Red flags documentali

Red flag	Possibile spiegazione	Azione
Foto non coerente	Documento datato o cambiamenti fisici.	Domande neutrali e confronto.
Dati sovrascritti	Danneggiamento o alterazione.	Sospendere e verificare.
Scadenza irregolare	Errore di lettura o documento non valido.	Non completare.
Documento mostrato solo in foto	Manca originale o modalità non prevista.	Applicare policy.
CF non coerente	Errore inserimento o identità dubbia.	Ricontrollare dati.
Rifiuto di farsi identificare	Privacy percepita o intento elusivo.	Spiegare obbligo; non operare.

Linguaggio corretto

Dire: "I dati non risultano sufficientemente verificabili per completare la pratica". Evitare: "Il documento è falso", salvo accertamento competente.

Una red flag non è prova di frode. È un fatto da documentare che aumenta il livello di verifica. Il sistema deve consentire note oggettive, allegati e stato sospeso.

05

Tracciabilità della pratica

La pratica deve ricostruire chi, cosa, quando, quanto e dove

5. Catena documentale

CATENA DI TRACCIABILITÀ



Ogni passaggio deve essere dimostrabile, autorizzato e ricostruibile.

La scheda numerata progressivamente è il centro della tracciabilità. Deve essere completa, leggibile e collegata a ricevuta, fotografie, pagamento e destinazione. Una pratica non è “completa” perché il PDF esiste: è completa se tutti gli elementi obbligatori sono coerenti.

Controllo	Domanda
Unicità	Il numero pratica è univoco e progressivo?
Temporalità	Data e ora riflettono l'operazione reale?
Identità	Il cliente è collegato alla pratica corretta?
Oggetti	Descrizione e fotografie rappresentano ciò che è stato acquistato?
Valore	Quotazione, criterio e importo sono ricostruibili?
Destinazione	È tracciato il passaggio successivo del bene?

05

Scheda operazione

Campi obbligatori e qualità del dato

5.1 Contenuto minimo

Area	Contenuto
Cliente	Dati identificativi e documento.
Pagamento	Estremi del mezzo non contante quando richiesto.
Oggetto	Natura, caratteristiche, qualità e stato.
Quotazione	Fonte affidabile e indipendente al momento dell'operazione.
Valutazione	Criteri riferiti a caratteristiche, qualità e stato.
Fotografie	Due immagini digitali da prospettive diverse.
Tempo	Data e ora dell'operazione.
Corrispettivo	Importo e mezzo di pagamento.
Destinazione	Cessione, trasformazione, fonderia o altra destinazione prevista.

Qualità del dato

Un campo compilato con testo generico può essere formalmente presente ma sostanzialmente inutile.
"Gioielli vari" non sostituisce una descrizione che permetta di riconoscere i beni.

La compilazione deve essere contemporanea o immediatamente collegata all'operazione. Ricostruire dopo giorni da memoria riduce affidabilità e aumenta il rischio di errori.

05

Fotografie, descrizione e ricevuta

Rendere l'oggetto riconoscibile anche dopo la consegna

5.2 Standard OroActive

Elemento	Standard minimo	Errore da evitare
Foto 1	Vista complessiva del lotto/oggetto.	Sfocata o coperta.
Foto 2	Prospettiva diversa o dettaglio utile.	Duplicato identico.
Dettagli	Punzoni, difetti, seriali se rilevanti.	Raccogliere dati inutili.
Descrizione	Tipo, colore, titolo dichiarato, peso, pietre, anomalie.	Termini vaghi.
Ricevuta	Riepilogo delle informazioni acquisite.	Mancata consegna.
Destinazione	Giacenza, altro operatore, fonderia, trasformazione.	Bene "scomparso" dal flusso.

Descrizione esempio

"Bracciale in metallo giallo, punzone 750 su chiusura, peso lordo 18,42 g, due inserti non metallici, segni d'uso e chiusura con componente magnetica; test pietra/acido coerente con 18K sulle parti selezionate."

Privacy e immagini

Le immagini servono a tracciabilità e obblighi normativi. Accesso, esportazione e condivisione devono essere limitati ai ruoli e alle finalità autorizzate.

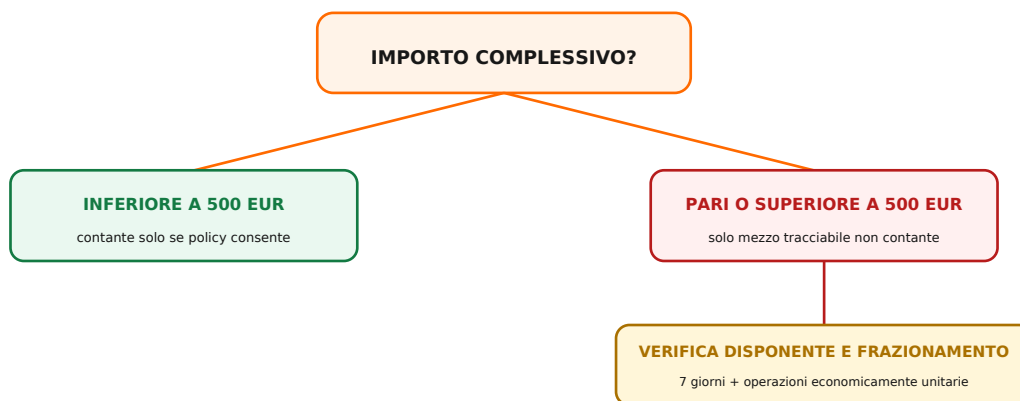
06

Limiti e modalità di pagamento

La soglia speciale del compro oro

6. Regola dei 500 euro

DECISIONE SUL MEZZO DI PAGAMENTO



Per le operazioni di importo pari o superiore a 500 euro, anche se frazionate, il pagamento deve avvenire con strumenti diversi dal contante che garantiscano tracciabilità e univoca riconducibilità al disponente. La soglia speciale va gestita sul valore economico complessivo dell'operazione, non sul singolo movimento isolato.

Importo	Mezzo	Controllo
< 500 EUR	Secondo legge e policy vigente.	Registrare importo e mezzo.
>= 500 EUR	Non contante e tracciabile.	Identificare disponente e collegare evidenza.
Frazionato	Considerare operazione unitaria.	Aggregare entro 7 giorni e oltre se collegata.

Errore critico

Dividere 800 euro in due pagamenti da 400 per usare contante non rende l'operazione conforme.

06

Frazionamento e disponente

Riconoscere operazioni economicamente unitarie

6.1 Collegare ciò che appare separato

Segnale	Esempio	Azione
Stesso cliente	Due vendite ravvicinate.	Somma e verifica finestra.
Stessi beni/origine	Lotto diviso in più pratiche.	Trattare unitariamente.
Stessa trattativa	Prezzo negoziato in un'unica sessione.	Unificare decisione.
Pagatore diverso	IBAN di terzo senza motivo.	Bloccare e chiarire.
Ripetizione entro 7 giorni	Importi sotto soglia ricorrenti.	Analisi frazionamento.
Oltre 7 giorni ma collegato	Schema ricorrente o accordo unico.	Valutare sostanza economica.

La finestra di sette giorni è un indicatore normativo importante, ma non esclude che operazioni oltre tale periodo siano collegate quando circostanze oggettive mostrano un'unica operazione economica.

Disponente

Il mezzo tracciabile deve consentire di ricondurre in modo univoco l'operazione al disponente. Un conto di terzi, una causale ambigua o una ricevuta incompleta richiedono verifica e autorizzazione.

06

Conto dedicato e riconciliazione

Il pagamento deve lasciare una catena economica verificabile

6.2 Controlli sul conto

Controllo	Evidenza
Conto corretto	Conto dedicato alla sede/operazioni secondo configurazione.
Un solo conto per sede	Nessuna pluralità di conti dedicati per la stessa sede.
Causale	Numero pratica e cliente secondo policy.
Importo	Corrisponde al corrispettivo autorizzato.
Beneficiario/disponente	Coerenti con la pratica o eccezione approvata.
Data	Compatibile con operazione e stato pratica.
Riconciliazione	Movimento bancario collegato e non riutilizzato.

Controllo di chiusura

Una pratica tracciabile sopra soglia non si chiude con “bonifico previsto”. Servono estremi del pagamento o lo stato corretto previsto dalla policy.

La riconciliazione deve impedire che un movimento venga collegato a più pratiche, che il pagamento resti orfano o che una pratica completata non abbia evidenza economica coerente.

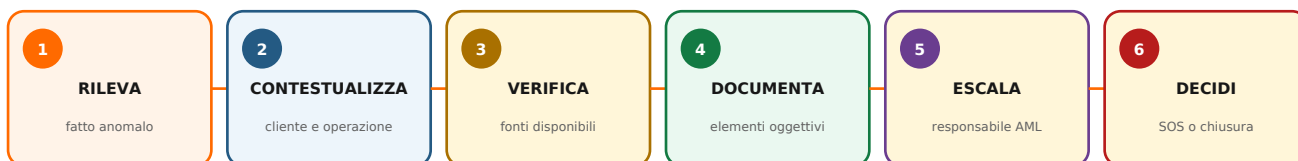
07

Approccio antiriciclaggio

Dall'anomalia al sospetto senza automatismi

7. Processo valutativo

VALUTAZIONE AML



Ogni passaggio deve essere dimostrabile, autorizzato e ricostruibile.

Un indicatore di anomalia non determina automaticamente una segnalazione. È un segnale da analizzare considerando cliente, beni, importo, frequenza, modalità di pagamento, spiegazioni ed eventuali informazioni già disponibili. Anche il contrario è vero: l'assenza di un indicatore elencato non esclude un sospetto.

Approccio errato	Approccio corretto
Segnalare ogni cliente che usa contante.	Valutare circostanze e operazione concreta.
Ignorare il cliente abituale.	Applicare controlli coerenti a tutti.
Usare nazionalità o aspetto come scorciatoia.	Basarsi su fatti pertinenti e non discriminatori.
Scrivere giudizi generici.	Documentare anomalie verificabili.

07

Indicatori di anomalia

Fatti oggettivi da combinare, non etichette

7.1 Domini di osservazione

Dominio	Esempi di anomalia
Cliente	Dati contraddittori, rifiuto di spiegazioni necessarie, terzi non giustificati.
Beni	Quantità, provenienza, tipologia o frequenza non coerenti con il profilo dichiarato.
Pagamento	Frazionamento, strumenti di terzi, urgenza anomala, cambio modalità.
Comportamento	Pressione, narrazione variabile, richiesta di evitare registrazioni.
Frequenza	Operazioni ravvicinate, negozi diversi, pattern ripetuti.
Documenti	Alterazioni, report non verificabili, numeri seriali duplicati.

Indicatori UIF

Gli indicatori pubblicati dalla UIF supportano l'analisi ma non sono esaustivi. L'organizzazione seleziona quelli pertinenti e considera ulteriori comportamenti anomali.

Il commesso deve registrare il fatto senza interpretazioni penali: "il cliente modifica tre volte la provenienza dichiarata" è utile; "il cliente ricicla denaro" è un'accusa non dimostrata.

07

Comportamenti e frequenze

Vedere il pattern oltre la singola pratica

7.2 Monitoraggio operativo

Pattern	Domanda di controllo	Possibile esito
Vendite frequenti	Origine e coerenza con profilo?	Monitoraggio/escalation.
Negozi diversi	Perché cambia sede?	Unificare storico rete.
Importi sotto soglia	C'è frazionamento?	Pagamento tracciabile/blocco.
Beni omogenei ripetuti	Attività professionale o provenienza?	Verifica superiore.
IBAN variabili	Chi è il disponente?	Non pagare senza chiarimento.
Urgenza e pressione	Motivo plausibile?	Sospendere se mina controlli.

Aurum Shield/CRM

Il sistema può evidenziare frequenze e collegamenti, ma la decisione deve restare motivata, verificabile e sottoposta ai ruoli competenti.

Le soglie interne di alert non devono trasformarsi in automatismi di colpevolezza. Servono a indirizzare una verifica proporzionata e coerente.

07

Escalation interna

Trasformare l'anomalia in un dossier utilizzabile

7.3 Scheda di escalation

Campo	Contenuto
Fatto osservato	Descrizione cronologica e neutrale.
Dati collegati	Pratiche, cliente, negozi, importi, pagamenti.
Verifiche svolte	Controlli, fonti e risultati.
Spiegazione cliente	Riportata senza giudizi.
Anomalie residue	Cosa non è stato risolto.
Stato pratica	Bozza, sospesa, non eseguita, completata.
Urgenza	Operazione imminente o già eseguita.
Allegati	Documenti, foto, log e ricevute.

Separazione dei ruoli

Il commesso segnala internamente; il responsabile designato valuta l'eventuale SOS secondo procedura.
Non condividere il dossier con colleghi non autorizzati.

La qualità dell'escalation dipende dalla completezza e non dal volume: pochi fatti ben documentati sono più utili di note lunghe e speculative.

08

Segnalazione di operazione sospetta

Tempestività, completezza e canale corretto

8. Dal sospetto alla UIF

Fase	Responsabilità
Rilevazione	Operatore/controlli interni.
Esame	Responsabile SOS/ruolo designato.
Decisione	Soggetto competente secondo procedura.
Compilazione	Dati, motivazione e operazioni collegate.
Invio	Canale Infostat-UIF e credenziali autorizzate.
Conservazione	Dossier riservato e accessi limitati.
Monitoraggio	Ulteriori eventi e flussi di ritorno.

La SOS deve essere inviata senza ritardo quando ricorrono i presupposti, preferibilmente prima dell'esecuzione quando possibile. La procedura interna deve evitare che il passaggio tra ruoli disperda tempo o informazioni.

Nessun automatismo

Un livello di rischio alto o l'uso del contante non determina da solo una SOS. Servono circostanze soggettive e oggettive che fondino il sospetto.

Accesso ristretto

Il numero di persone a conoscenza della SOS deve essere limitato a chi ne ha necessità funzionale.

08

Riservatezza e no tipping off

Non compromettere analisi e indagini

8.1 Cosa non comunicare

Situazione	Comunicazione consentita	Da evitare
Pratica in verifica	"Servono controlli aggiuntivi secondo procedura."	Rivelare valutazione AML.
Ritardo pagamento	"La pratica non è ancora autorizzata."	Dire che la UIF sta valutando.
Richiesta informazioni	Fare domande pertinenti e neutrali.	Spiegare che si prepara una SOS.
Collega curioso	Nessuna condivisione non necessaria.	Commenti informali.
Cliente insiste	Ribadire regole e tempi.	Minacciare segnalazioni.

Segreto e riservatezza

Informazioni relative a una SOS, alla sua valutazione o a un provvedimento UIF sono riservate. Non sono ostensibili al cliente o a terzi non autorizzati.

Anche le note nel gestionale devono essere visibili solo ai ruoli abilitati. Un testo in un campo comune o in una notifica generale può costituire una divulgazione indebita.

08

Sospensione interna e sospensione UIF

Due strumenti diversi da non confondere

8.2 Distinzione essenziale

Aspetto	Sospensione interna OroActive	Sospensione UIF
Fondamento	Policy e gestione rischio.	Provvedimento/iter previsto da AML.
Chi decide	Ruolo aziendale autorizzato.	UIF secondo legge.
Scopo	Non concludere pratica incompleta o rischiosa.	Fermare operazione sospetta valutata.
Durata	Secondo workflow e motivazione.	Massimo cinque giorni lavorativi dal provvedimento.
Comunicazione	Motivo operativo generico.	Segreta, non rivelabile al cliente.
Esito	Riapertura, rifiuto, verifica, escalation.	Revoca/scadenza e indicazioni ricevute.

Errore grave

Non presentare una sospensione interna come ordine dell'autorità. Non rivelare che un ritardo dipende da valutazioni UIF.

Quando la UIF avvia la valutazione di un'operazione non eseguita ai fini della sospensione, il destinatario si astiene dall'eseguirlo e monitora eventuali variazioni, seguendo le istruzioni riservate.

09

Principi privacy

La conformità dei dati inizia prima della raccolta

9. Sei principi operativi

CICLO DI VITA DEL DATO*Ogni passaggio deve essere dimostrabile, autorizzato e ricostruibile.*

Principio	Traduzione operativa
Liceità, correttezza, trasparenza	Base giuridica e informativa comprensibile.
Limitazione finalità	Uso solo per scopi dichiarati e autorizzati.
Minimizzazione	Solo dati adeguati e necessari.
Esattezza	Correggere dati errati e mantenere qualità.
Limitazione conservazione	Tempi definiti per categoria.
Integrità e riservatezza	Accessi, cifratura, backup e controllo.
Accountability	Essere in grado di dimostrare le misure.

Doppio vincolo

La legge speciale impone di conservare determinate informazioni per 10 anni; il GDPR impone di non usare quei dati per finalità diverse e di proteggerli per tutto il periodo.

09

Base giuridica e informativa

Non usare il consenso come formula universale

9.1 Perché trattiamo i dati

Trattamento	Base tipica da verificare	Nota
Identificazione e scheda	Obbligo legale.	Non dipende dal consenso del cliente.
Pagamento e contabilità	Obbligo legale/contratto.	Finalità definita.
Sicurezza e antifrode	Obbligo/legittimo interesse secondo analisi.	Proporzionalità.
Marketing	Consenso o altra base applicabile.	Separato dall'operazione.
Formazione con dati reali	Normalmente non necessaria.	Usare dati demo/anonimizzati.

L'informativa deve essere fornita prima della raccolta e descrivere titolare, finalità, base giuridica, destinatari, tempi, diritti e contatti del DPO se presente. Deve essere accessibile e non nascosta in documenti incomprensibili.

Consenso

Non chiedere un consenso fittizio per attività obbligatorie: il cliente non può "revocare" l'identificazione prevista dalla legge e continuare l'operazione.

09

Minimizzazione e copie documenti

Raccogliere ciò che serve, non ciò che è comodo

9.2 Immagini e allegati

Dato/immagine	Domanda prima della raccolta
Fronte/retro documento	È richiesto dalla procedura approvata e dalla base giuridica?
Tessera sanitaria/CF	Serve il dato o anche l'immagine?
Selfie cliente	È previsto e proporzionato?
IBAN	Serve per il pagamento e come viene verificato?
Note libere	Contengono dati eccedenti o giudizi?
Foto oggetti	Rappresentano i beni senza includere dati estranei?

Regola

Non conservare copie di documenti “per sicurezza” senza una base e un periodo approvati. La raccolta eccessiva aumenta rischio, costi e impatto di un data breach.

La mascheratura di dati non necessari, la qualità controllata e l'accesso per ruolo sono preferibili alla raccolta indiscriminata. Le immagini devono essere associate alla pratica corretta e non restare nel rullino personale del dispositivo.

10

Conservazione documentale

Dieci anni con integrità, accessibilità e storicità

10. Obbligo speciale

Elemento	Periodo/criterio	Requisito
Dati identificativi cliente	10 anni.	Accessibilità completa e tempestiva.
Scheda operazione	10 anni.	Integrità e non alterabilità.
Copia ricevuta	10 anni.	Completezza e chiarezza.
Fotografie e allegati collegati	Secondo obbligo e policy.	Collegamento alla pratica.
Log e versioni	Secondo necessità di storicità/audit.	Ricostruzione dell'evento.
Dati ulteriori	Tempo necessario alla finalità.	Schedule approvata.

Non alterabilità

Correggere non significa sovrascrivere. Il sistema deve conservare valore precedente, nuovo valore, autore, ora e motivo.

Al termine del periodo, l'eliminazione o anonimizzazione deve seguire un processo autorizzato, registrato e coerente con contenziosi, blocchi legali e altre basi di conservazione.

10

Accessibilità, integrità e storicità

La conservazione deve funzionare quando serve

10.1 Requisiti tecnici e organizzativi

Requisito	Controllo
Accessibilità	Ricerca rapida per pratica, cliente, data e negozio.
Integrità	Hash, firme, versioni o meccanismi equivalenti.
Non alterabilità	Append-only o audit immutabile per eventi critici.
Completezza	Campi obbligatori e allegati presenti.
Chiarezza	Formati leggibili e metadati comprensibili.
Storicità	Collegamento tra tutte le versioni ed eventi.
Disponibilità	Backup, restore test e continuità.

Test reale

Un backup non è affidabile finché non è stato ripristinato e verificato. Un archivio non è conforme se i file esistono ma non si riesce a collegarli alla pratica.

La migrazione di sistemi deve preservare metadati, numerazione, timestamp, allegati e audit. La semplice copia dei PDF non conserva necessariamente tutta la storia operativa.

10

Diritti e richieste privacy

Gestire richieste senza distruggere obblighi legali

10.2 Flusso controllato

Richiesta	Azione commesso	Ruolo competente
Accesso ai dati	Registrare e inoltrare.	Privacy/DPO.
Rettifica	Non modificare senza procedura.	Privacy + responsabile.
Cancellazione	Non promettere cancellazione immediata.	Titolare/DPO valuta obblighi.
Limitazione	Bloccare uso secondo istruzioni.	Privacy/IT.
Opposizione marketing	Registrare e applicare.	Marketing/privacy.
Reclamo	Accogliere, non discutere, inoltrare.	Direzione/privacy.

Conservazione obbligatoria

Il diritto alla cancellazione non elimina automaticamente dati che devono essere conservati per un obbligo legale. La risposta va gestita dal ruolo competente.

Il commesso non invia estrazioni o documenti al cliente da canali personali. Ogni risposta deve seguire verifica dell'identità del richiedente e canali approvati.

11

Audit trail

Trasformare ogni azione critica in una prova ricostruibile

11. Anatomia del log

TRACCIA DI AUDIT MINIMA



Ogni passaggio deve essere dimostrabile, autorizzato e ricostruibile.

Evento da loggare	Esempio
Creazione/modifica pratica	Campi anagrafici, oggetti, importi.
Cambio stato	Bozza, sospesa, completata, archiviata, eliminata.
Autorizzazione/override	Chi, perché e quale soglia.
Accesso/esportazione	Documenti, foto e report sensibili.
Pagamento	Generazione, modifica, riconciliazione.
Cancellazione logica	Oggetto, motivo e approvazione.
Incident response	Contenimento e ripristino.

Immutabilità

L'utente che genera l'evento non deve poter riscrivere il log. La correzione genera un nuovo evento.

11

Identità digitale e privilegi

Nessun account condiviso, nessun ruolo onnipotente

11.1 Least privilege

Controllo	Standard
Account individuale	Un utente per persona.
MFA	Per ruoli e accessi critici.
Ruolo minimo	Solo funzioni necessarie.
Sessione	Timeout, revoca e dispositivo.
Founder/admin	Uso motivato e tracciato.
Cessazione rapporto	Revoca immediata.
Revisione periodica	Conferma accessi e negozi.
Segreti/API key	Mai in client o messaggi.

Account condiviso

Impedisce attribuzione, aumenta rischio e rende l'audit debole. Le credenziali non si prestano, neppure "per cinque minuti".

Le autorizzazioni devono essere applicate anche lato backend: nascondere un bottone nel frontend non impedisce una chiamata non autorizzata.

11

Backup, log e ripristino

Proteggere disponibilità senza duplicare il rischio

11.2 Continuità dei dati

Area	Controllo
Backup	Frequenza, cifratura, retention e separazione.
Restore	Test periodico con esito documentato.
Log	Raccolta centralizzata e protezione da alterazione.
Alert	Accessi anomali, export massivi, errori ripetuti.
RPO	Quanto dato si può perdere.
RTO	Quanto tempo per ripristinare.
Copia offline/immutabile	Protezione da ransomware.

Dati nei backup

La cancellazione e la retention devono considerare le copie di sicurezza. I backup non devono diventare archivi indefiniti e non governati.

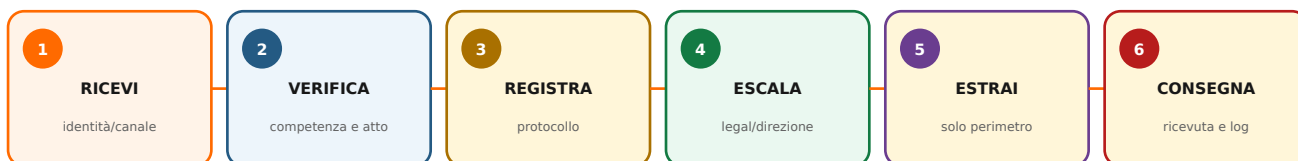
La disponibilità è parte della sicurezza: un sistema non accessibile può impedire identificazione, tracciabilità e risposta alle autorità. Il piano deve stabilire quando sospendere l'operatività.

12

Rapporti con autorità

Collaborare correttamente, senza improvvisare o divulgare troppo

12. Identificazione della richiesta

GESTIONE RICHIESTA AUTORITÀ

Ogni passaggio deve essere dimostrabile, autorizzato e ricostruibile.

Verifica	Domanda
Identità	Chi richiede e con quale qualifica?
Canale	PEC, atto, presenza fisica o altro canale ufficiale?
Oggetto	Quali pratiche, date, clienti o documenti?
Base e urgenza	Quale titolo e quale termine?
Perimetro	Quali dati sono richiesti e quali esclusi?
Consegna	Come documentare copie, originali e ricezione?

Comportamento

Essere collaborativi non significa consegnare dati a chiunque si presenti come autorità. Verificare e coinvolgere immediatamente il ruolo competente.

12

Ispezione in sede

Preservare operatività, evidenze e diritti

12.1 Protocollo di accoglienza

1. Accogliere con calma e chiedere identificazione ufficiale e oggetto dell'accesso.
2. Informare immediatamente responsabile/direzione/legal secondo piano.
3. Registrare ora di arrivo, nominativi, ente e documenti esibiti.
4. Mettere a disposizione una persona referente; evitare risposte non verificate.
5. Non cancellare, modificare o spostare dati/beni dopo l'avvio della richiesta.
6. Fornire solo ciò che rientra nel perimetro autorizzato, mantenendo una lista delle consegne.
7. Richiedere verbale o ricevuta per originali, copie e beni prelevati.
8. Conservare copia dei verbali e attivare follow-up interno.

Divieto assoluto

Non occultare, distruggere, correggere retroattivamente o coordinare versioni tra colleghi. Qualsiasi dubbio va portato al referente legale.

Durante l'ispezione	Regola
Domande	Rispondere su fatti conosciuti, non ipotizzare.
Password	Seguire istruzioni IT/legal, non comunicare credenziali personali impropriamente.
Clienti presenti	Proteggere riservatezza e continuità.
Foto/video	Seguire indicazioni e documentare l'evento.

12

Catena di custodia

Ogni consegna deve essere integra e dimostrabile

12.2 Originali, copie e supporti

Elemento	Da registrare
Documento/oggetto	Descrizione univoca.
Origine	Pratica, sistema, cartella o dispositivo.
Formato	Originale, copia, export, immagine, supporto.
Hash/seriale	Se previsto e disponibile.
Consegna	Data, ora, persona e ente.
Sigillo/contenitore	Numero e integrità.
Ricevuta	Firma o verbale.
Copia trattenuta	Dove e con quale accesso.

Export dati

Un export per autorità deve essere riproducibile, completo nel perimetro, protetto durante il trasferimento e registrato nell'audit.

Se si consegnano originali necessari all'operatività, documentare l'assenza e applicare la procedura di continuità. Non creare copie personali o inviarle tramite canali non autorizzati.

13

Sospensione della pratica

Fermare il processo prima che un dubbio diventi errore

13. Matrice di rischio

MATRICE DI SOSPENSIONE INTERNA

	0 - coerente	1 - verifica	2 - sospendi
Dati cliente	completo	dubbio	incoerente
Documento	valido	da chiarire	falso/scaduto
Pagamento	coerente	anomalo	non tracciabile
Oggetti	coerenti	test discordi	struttura critica
Comportamento	ordinario <i>Un singolo trigger critico può imporre stop anche con punteggio totale basso.</i>	pressione	minaccia/frode

Trigger critico	Esempio
Identità non verificabile	Persona/documento non coerenti.
Pagamento non tracciabile	Sopra soglia o disponente non giustificato.
Oggetto critico	Test discordanti, seriale duplicato, struttura sospetta.
Dati mancanti	Foto, firme, campi o ricevuta non completabili.
Comportamento pericoloso	Minaccia, coercizione o tentativo di elusione.
Sistema non affidabile	Numerazione, salvataggio o database non disponibili.

Stop rule

Un singolo trigger critico può bastare per sospendere anche se gli altri elementi sono coerenti.

13

Autorizzazioni e override

Un'eccezione deve essere rara, motivata e misurabile

13.1 Quattro domande prima di autorizzare

Test dell'override

1. La regola consente realmente una deroga?
2. Il rischio residuo è compreso e accettabile?
3. L'autorizzatore ha ruolo e informazioni sufficienti?
4. L'evidenza consente a un auditor di capire la decisione?

Campo override	Contenuto
Regola superata	Campo/blocco/soglia.
Motivo	Fatto specifico, non "urgenza".
Controlli compensativi	Seconda verifica, documento aggiuntivo, limite.
Autorizzatore	Utente e ruolo.
Validità	Singola pratica o periodo definito.
Esito	Completata, sospesa, rifiutata.

Mai override

Identità non verificata, pagamento illegale, ordine autorità, SOS/riservatezza, integrità audit o sicurezza personale non sono deroghe commerciali.

13

Comunicazione al cliente

Essere trasparenti senza divulgare informazioni riservate

13.2 Frasi operative

Situazione	Formula consigliata
Documento insufficiente	"Non riesco a completare la verifica necessaria per questa operazione."
Pagamento da terzo	"Il pagamento deve essere ricondotto al disponente previsto dalla procedura."
Pratica sospesa	"Servono controlli aggiuntivi prima di poter concludere."
Tempo di attesa	"La pratica è in verifica interna; ti aggiorneremo tramite il canale concordato."
Rifiuto	"Non possiamo procedere con questa operazione secondo la procedura applicabile."
Richiesta motivi AML	"Non posso fornire dettagli su verifiche riservate interne."

Tono

Calmo, neutrale, non accusatorio. Non negoziare un obbligo legale e non promettere tempi o esiti non autorizzati.

La comunicazione va registrata quando incide sulla pratica. Evitare messaggi personali, vocali non archiviati o informazioni riservate in chat non approvate.

14

Incident management

Riconoscere, contenere, comunicare, recuperare

14. Un incidente non è solo informatico

CICLO DI GESTIONE INCIDENTE



Ogni passaggio deve essere dimostrabile, autorizzato e ricostruibile.

Categoria	Esempi
Fisico	Furto, rapina, intrusione, perdita chiavi.
Operativo	Numero atto duplicato, pagamento errato, lotto mancante.
Privacy	Documento inviato al destinatario sbagliato.
Cyber	Phishing, malware, account compromesso.
Disponibilità	Database o app non raggiungibile.
Integrità	Dati modificati o log mancanti.

Priorità

1) sicurezza delle persone; 2) contenimento; 3) conservazione delle evidenze; 4) comunicazione ai ruoli; 5) ripristino controllato.

14

Incidente fisico

Rapina, furto, manomissione e perdita di beni

14.1 Prima le persone, poi il patrimonio

Evento	Azione immediata
Rapina/minaccia	Non reagire; attivare protocollo di sicurezza.
Intrusione	Non entrare; chiamare canali previsti.
Sigillo rotto	Isolare, fotografare, bloccare stato.
Bene mancante	Congelare movimenti e fare inventario controllato.
Chiave/badge perso	Revocare accesso e cambiare controllo.
Videosorveglianza	Preservare secondo policy e richiesta competente.

1. Mettere in sicurezza persone e area.
2. Non alterare scena, contenitori o registri.
3. Avvisare responsabile e forze dell'ordine secondo protocollo.
4. Registrare ora, testimoni, beni e sistemi coinvolti.
5. Proteggere log, video e audit da sovrascrittura.
6. Riconciliare fisico, software e contabilità dopo autorizzazione.

Supporto alle persone

Dopo un evento violento, la gestione include assistenza, comunicazione interna controllata e prevenzione della colpevolizzazione.

14

Incidente operativo

Un errore di processo può diventare perdita o violazione

14.2 Numerazione, pagamenti e pratiche

Incidente	Contenimento
Numero atto duplicato	Bloccare entrambe le pratiche e verificare sequenza.
Atto "scomparso"	Non ricreare da zero; cercare stato/database/audit.
Pagamento errato	Contattare finance e bloccare ulteriori movimenti.
IBAN sbagliato	Non inviare nuovo pagamento senza riconciliare.
Foto/documento errato	Limitare accesso, correggere collegamento con audit.
Eliminazione accidentale	Ripristinare da versione/backup senza cancellare evento.

Regola

La correzione non deve nascondere l'errore. Deve ripristinare stato corretto lasciando visibile causa, impatto, autore e autorizzazione.

Se l'errore coinvolge dati personali, verificare anche se è un data breach. Se coinvolge pagamenti o beni, avviare riconciliazione economica e fisica.

14

Incidente cyber

Account, dispositivo e applicazione sotto attacco

14.3 Segnali e prime azioni

Segnale	Azione
Login inatteso	Revoca sessioni e cambio credenziali.
MFA non richiesto dall'utente	Non approvare; segnalare.
Email con allegato/link anomalo	Non aprire; inoltrare al canale sicurezza.
Dispositivo perso	Blocco remoto e valutazione dati.
Ransomware/errore massivo	Isolare rete/dispositivo, non improvvisare.
Export anomalo	Revocare accesso e preservare log.

Non distruggere prove

Non formattare il dispositivo, cancellare email o spegnere sistemi critici senza istruzioni. Il contenimento deve preservare evidenze.

Il commesso comunica rapidamente cosa è successo, quando, su quale dispositivo, quale account e quali dati erano aperti. Non serve diagnosticare l'attacco: serve fornire fatti affidabili.

15

Data breach

Perdita di riservatezza, integrità o disponibilità

15. Classificare la violazione

Dimensione	Esempio
Riservatezza	Documento cliente inviato alla persona sbagliata.
Integrità	Dati anagrafici o importi alterati.
Disponibilità	Archivio inaccessibile per malware o errore.
Multipla	Furto di tablet non cifrato con dati modificabili.
Fattore rischio	Domanda
Tipo di dati	Documenti, CF, IBAN, foto, firme?
Volume	Quante persone e record?
Identificabilità	Dati cifrati o leggibili?
Conseguenze	Frode, furto identità, danno economico/reputazione?
Destinatario	Affidabile, sconosciuto, pubblico?
Recuperabilità	Il dato è stato cancellato/recuperato?

Tutte si documentano

Non tutte le violazioni richiedono notifica al Garante, ma tutte devono essere registrate e valutate dal titolare con i ruoli competenti.

15

Le prime 72 ore

La velocità nasce da ruoli e prove già preparati

15.1 Timeline operativa

CRONOLOGIA DI RISPOSTA AL DATA BREACH



Tutte le violazioni si documentano; non tutte richiedono notifica. La valutazione spetta al titolare con DPO/legal/security.

1. T0: chi rileva informa immediatamente il canale incident/privacy.
2. Contenimento: revoca accessi, recupera email, blocca device o limita condivisione.
3. Preservazione: conserva log, messaggi, timestamp e configurazioni.
4. Scoping: quali dati, persone, sistemi e terzi sono coinvolti?
5. Rischio: probabilità e gravità per diritti e libertà.
6. Decisione: notifica al Garante se dovuta, ove possibile entro 72 ore.
7. Comunicazione interessati: se rischio elevato, salvo eccezioni applicabili.
8. Registro: documenta fatto, effetti e misure in ogni caso.

Il commesso non notifica

Il commesso attiva subito la catena. La decisione e la notifica spettano al titolare e ai ruoli designati.

15

Notifica, comunicazione e registro

Tre output diversi

15.2 Contenuti minimi

Output	Destinatario	Contenuto
Registro breach	Interno/autorità su richiesta.	Fatti, effetti, valutazione e misure.
Notifica	Garante, quando dovuta.	Natura, categorie, contatti, conseguenze, misure.
Comunicazione	Interessati, se rischio elevato.	Linguaggio chiaro, rischi e protezioni.
Comunicazione interna	Ruoli necessari.	Istruzioni operative, non gossip.

Trasparenza controllata

Informare non significa pubblicare dettagli tecnici che aumentano il rischio. La comunicazione deve essere utile alla persona e coordinata con legal/security.

Una notifica oltre 72 ore deve spiegare il ritardo. La comunicazione agli interessati non va rimandata quando il rischio è elevato solo perché la notifica al Garante è stata inviata.

16

Business continuity

Continuare solo se il controllo resta equivalente

16. Operatività in emergenza

Scenario	Decisione
App non disponibile	Usare fallback solo se approvato e numerato.
Database non raggiungibile	Non creare pratiche parallele non riconciliabili.
Pagamento non verificabile	Non completare sopra soglia.
Scanner/foto guasti	Usare dispositivo autorizzato o sospendere.
Internet assente	Applicare procedura offline e successiva riconciliazione.
Backup non disponibile	Valutare stop operativo.

Fallback sicuro

1. Autorizzazione formale all'avvio del fallback.
2. Moduli pre-numerati e custoditi.
3. Raccolta degli stessi dati obbligatori.
4. Nessuna duplicazione di numeri o pagamenti.
5. Inserimento nel sistema e riconciliazione a ripristino.
6. Chiusura dell'incidente e verifica campione.

Stop operativo

Se non è possibile identificare, fotografare, tracciare o pagare secondo legge, la continuità corretta è sospendere l'operazione.

16

Fornitori e accessi remoti

La responsabilità non si esternalizza

16.1 Terze parti

Controllo fornitore	Evidenza
Contratto e ruoli privacy	Titolare/responsabile, istruzioni e subfornitori.
Accesso remoto	Autorizzato, temporaneo, MFA e log.
Dati trattati	Minimo necessario e localizzazione.
Incidenti	Tempi di notifica e contatti.
Backup/restore	Obiettivi e test.
Cessazione	Restituzione/cancellazione dati e revoca accessi.
Audit	Report, certificazioni e verifiche.

Supporto tecnico

Non inviare documenti cliente in chat al fornitore. Usare strumenti, ticket e accessi previsti, con mascheratura quando possibile.

La password condivisa “per l’assistenza” crea un accesso non attribuibile. Preferire account nominativi, elevazione temporanea e registrazione della sessione secondo policy.

16

Sicurezza quotidiana

Le violazioni spesso iniziano da gesti ordinari

16.2 Dispositivi, carta e comunicazioni

Comportamento	Standard
Schermo	Bloccare quando ci si allontana.
Documenti cartacei	Non lasciarli sul banco; distruzione sicura.
Foto	Solo app/dispositivo autorizzato.
Email	Verificare mittente, dominio e richiesta.
USB	Solo se autorizzate e controllate.
Wi-Fi	Reti approvate; niente hotspot personali per dati sensibili.
Stampa	Ritirare subito e verificare destinatario.
Conversazioni	Evitare dati cliente in aree pubbliche.

Phishing

Una richiesta urgente di password, bonifico, export o codice MFA è un segnale. Fermarsi, verificare con canale indipendente e segnalare.

La sicurezza non è delegata all'IT: il primo controllo è spesso la scelta dell'utente di non cliccare, non condividere e non aggirare il processo.

17

KPI e controlli

Misurare la qualità, non solo il numero di pratiche

17. Cruscotto di conformità

KPI	Significato	Segnale
Pratiche incomplete	Campi/allegati mancanti.	Formazione o bug.
Sospensioni per motivo	Tipologia e trend.	Rischio emergente.
Override	Numero, ruolo e risultato.	Soglie aggirate.
Pagamenti non riconciliati	Movimenti orfani o ritardi.	Rischio economico.
Accessi anomali	Fuori orario/export.	Rischio insider/cyber.
Restore test	Esito e tempo.	Resilienza reale.
Incidenti/data breach	Volume, severità, tempo risposta.	Efficacia controlli.
Formazione/esami	Copertura e risultati.	Competenza.

KPI sano

Una riduzione delle sospensioni non è sempre positiva: può indicare che gli operatori non segnalano. Leggere quantità insieme a qualità e casi campione.

I KPI devono portare a cause radice, azioni, responsabili e scadenze. Una dashboard senza follow-up è solo decorazione.

17

Sanzioni e responsabilità

La conformità protegge cliente, operatore e impresa

17.1 Conseguenze degli errori

Area	Possibile conseguenza
Identificazione/conservazione	Sanzioni amministrative e debolezza probatoria.
SOS	Sanzioni per omessa o tardiva segnalazione e rischio investigativo.
Pagamenti	Violazione regole speciali e tracciabilità.
Privacy	Provvedimenti, sanzioni, risarcimenti e reputazione.
Audit/manomissione	Perdita di affidabilità e possibili responsabilità ulteriori.
Esercizio abusivo	Responsabilità penale prevista dalla legge speciale.
Policy	Misure disciplinari e revoca deleghe.

Cultura giusta

L'errore segnalato tempestivamente permette di contenere. L'errore nascosto, ripetuto o manipolato aumenta il danno e la responsabilità.

La formazione deve evitare sia il terrore della norma sia la banalizzazione. L'obiettivo è una condotta ripetibile, proporzionata e documentata.

18

Caso studio 1

Cliente, pagamento e frequenza anomala

18. Analisi guidata

Scenario: cliente già noto vende gioielli per 320 euro lunedì, 280 euro giovedì e 460 euro il martedì successivo. Chiede che il secondo pagamento vada sul conto di un parente e insiste sul contante perché “sono pratiche diverse”. Il documento è valido; gli oggetti superano i test di primo livello.

Passaggio	Analisi
Identità	Valida, ma non esaurisce il controllo.
Frazionamento	Le operazioni ravvicinate e collegate richiedono aggregazione sostanziale.
Pagamento	Il conto del parente non è coerente senza valida giustificazione/procedura.
Comportamento	Richiesta esplicita di evitare tracciabilità è anomala.
Beni	Test coerenti, ma frequenza/provenienza vanno contestualizzate.
Decisione operativa	Sospendere pagamento/pratica, documentare, escalare.
AML	Il responsabile valuta il complesso dei fatti, senza automatismi.

Risposta corretta

Non accusare il cliente. Spiegare che le operazioni collegate e la modalità di pagamento richiedono controlli e autorizzazioni ulteriori.

Evidenze da preservare: pratiche collegate, orari, importi, richieste di pagamento, IBAN, note oggettive, fotografie e messaggi su canali autorizzati.

18

Caso studio 2

Documento inviato al destinatario sbagliato

18.1 Data breach e risposta

Scenario: un operatore esporta la ricevuta di una pratica e la invia via email a un cliente omonimo. Il PDF contiene dati anagrafici, codice fiscale, estremi documento, foto dei beni, importo e IBAN. Il destinatario comunica l'errore dopo 20 minuti e dichiara di aver eliminato l'allegato.

Fase	Azione
Rilevazione	Aprire incidente immediatamente.
Contenimento	Chiedere eliminazione, richiamare messaggio se possibile, bloccare ulteriori invii.
Preservazione	Conservare email, log, destinatario, ora e file.
Scoping	Un interessato, dati identità/finanziari e foto.
Rischio	Valutare furto identità/frode e affidabilità destinatario.
Decisione	Titolare/DPO decide notifica e comunicazione.
Correzione	Verifica destinatario, doppio controllo, protezione allegati.

Non basta “ha cancellato”

La dichiarazione del destinatario riduce ma non elimina automaticamente il rischio. La violazione deve essere documentata e valutata.

Il commesso non contatta autonomamente il Garante e non promette al cliente che “non è successo niente”. Attiva il piano, collabora con i fatti e segue le comunicazioni approvate.

18

Check-list, esame e fonti

Verifica finale della competenza

18.2 Scheda rapida

Prima di completare una pratica	OK
Cliente identificato prima dell'operazione	[]
Documento valido e dati coerenti	[]
Scheda progressiva completa	[]
Descrizione e due foto adeguate	[]
Quotazione e valutazione ricostruibili	[]
Pagamento conforme, frazionamento verificato	[]
Ricevuta pronta e destinazione tracciata	[]
Nessuna anomalia aperta o non autorizzata	[]
Audit, firme e allegati presenti	[]

Struttura esame

Prova	Soglia
50 domande normative e operative	80%
Simulazione identificazione/documenti	Nessun errore bloccante
Caso pagamento e frazionamento	Decisione e motivazione corrette
Caso AML/SOS	Escalation e riservatezza corrette
Tabletop data breach	Timeline e prove complete
Colloquio su autorità/audit	Idoneo

Fonti ufficiali consultate

D.Lgs. 25 maggio 2017 n. 92; D.Lgs. 21 novembre 2007 n. 231; Istruzioni e indicatori UIF; Regolamento (UE) 2016/679; Codice Privacy e materiali del Garante; indicazioni OAM sul conto dedicato. Verificare sempre le versioni vigenti e la policy aziendale.



OPERATORE AUTONOMO SIGNIFICA OPERATORE CONFORME, TRACCIABILE E PRUDENTE

Identità certa, pratica completa, pagamento coerente, dati protetti e decisioni dimostrabili.
Cinque condizioni che proteggono cliente, negozio e valore.

Principio OroActive

La sicurezza non è un ostacolo alla vendita. È il metodo che consente di concludere le operazioni corrette, fermare quelle non verificabili e dimostrare ogni decisione nel tempo.

Aggiornamento normativo consultato: 22 giugno 2026. Corso interno da riesaminare a ogni modifica normativa, organizzativa, tecnologica o di policy.